Ms08067安全实验室-红队攻防实战培训班 第5期

#####学习更多红队实战技术，欢迎加入我们，详细授课大纲见公众号介绍（二维码在文章底部）

自我介绍：研究方向，从事红队场数

对安全行业的看法：红队不应该有短板，只能有很多标准板和长板。

被动信息收集

1.课程介绍

第1天课 信息收集总体概念

被动信息收集
信息收集的总体概念以及在整个红队流程中的位置；
被动信息收集的基本结构和基本逻辑；
被动信息收集的常见手段（网络空间搜索、被动信息收集工具、传统搜索）；
被动信息收集后的信息处理；
被动信息收集工具的底层原理以及如何编写；

第2天课 主动信息收集
信息收集完成之后的信息综合处理
主动信息收集的基本结构和基本逻辑；
主动信息收集的常见手段（仅限扫描的nmap和扫描带有poc的goby）；
主动信息收集后的信息处理；
主动信息收集工具的底层原理以及如何编写；
如何将主动信息收集和被动信息收集的信息综合处理；
收集到的信息如何衔接到下一步的红队流程中；

第3天课 社会工程学
社会工程学的含义以及实际应用；
社会工程学的知识体系；
社会工程学的学习方法；

第4天课 社会工程学中的交互
社会工程学中的常见钓鱼方式以及应用；
社会工程学中如何根据收集到的信息利用目标的社会属性弱点进行交互；
社会工程学中的信任获得和信任利用方式

第5天课 简易的远控终端
使用的编程语言及相关知识基础
payload的基本结构和编程语言的实战；
编写一个简易的远控终端

第6天课 实战中的快速审计
寻找源码中的多种途径
快速查找源码中可利用的脆弱点
使用工具发现脆弱点

第7天课 POC的编写
Java类与对象的概念
Java中基础语法的学习
POC编写应具备的哪些条件
Idea工具的安装

第8天课 POC的编写
本地IO进行内容读写
网络请求进行发包模拟
POC实战

第9天课 痕迹清理
Windows操作系统的痕迹清理
Windows痕迹清理的基本思路和思考逻辑；
Windows清理操作痕迹；
Windows清理时间痕迹
Linux操作系统的痕迹清理
Linux痕迹清理的基本思路和思考逻辑；
Linux清理登录痕迹；
Linux清理操作痕迹；
Lnux清理时间痕迹

本次系列课程主要训练内容为红队攻防过程中的思维模型和逻辑思考。

每天一遍提醒：养成良好的习惯很重要，每天花10-20分钟时间阅读最新的文章，对自己感兴趣的点去学习。

https://www.freebuf.com/

https://www.4hou.com/

https://www.anquanke.com/

https://xz.aliyun.com/

https://paper.seebug.org/

https://www.ddosi.org/

公网IP
nps

推荐大家同学有一个自己的服务器。

代理

学完之后大概是什么水平：

逻辑思路和相关操作

需要的东西：

知识面和积累的差距

每节课我都会讲这部分知识我有哪些是没有讲到

大家之后就可以拿着我这个基本的逻辑思考去学习新的知识

2.基本的红队测试流程介绍

1.接到项目合同并制定相应计划

2.准备相应的工具和材料

3.做第一次信息收集

4.做漏洞扫描或攻击面测试

5.针对突出的攻击面做具体的渗透

6.进入环境之后的第二次信息收集

7.提升权限

8.维持权限

9.寻找扩大攻击面的渠道

10.清理攻击痕迹

11.编写报告

3.信息收集在整个流程中的定位

渗透的本质是信息收集，攻防的体系是知识点的串联。

每一步的攻击流程目的都是非常重要的。

如果最终达到的目的不需要某几步流程，那么就完全不用去做。

信息收集在整个渗透测试流程中是非常重要的步骤，是决定攻击是否成功的决定点。

信息收集决定之后的攻击面或漏洞扫描的范围，也决定整个攻击过程中对自己和目标的定位。

信息收集的基本要求：

1.全面：

做到对目标所有的业务面和非业务面的存在点进行全面的信息收集。

2.准确：

对于收集到的信息尤其是重要信息要再三确认其信息的准确性，对信息的内容中所涉及的技术点要手动查看。

3.时效：

对于收集到的信息要注意信息产生的时间和收集到的时间，是否具有时间差，时间差能否接受，如果存在失效的信息要及时清除。

4.清晰：

对于收集到的信息要做到逻辑清晰，能清楚地分辨出各个收集到的信息之间的逻辑关系和资产之间的相对位置，对于总体目标要有清晰的资产逻辑和业务逻辑认识。

域名	ip地址	端口	服务	状态	业务
aaa.com	1.1.1.1	80	apache		这个业务中哪个功能点会跳转到bbb.com
bbb.com	2.2.2.2				
ccc.com	1.1.1.1				

5.拓扑：

对于收集到的信息要以这些信息为起点做拓扑的信息收集。递归算法。

信息收集的底层逻辑：

通过各种渠道对于目标已公开或未公开的信息做提取。

信息收集最重要的注意事项：

降低被发现度，提高隐蔽性。

细心，耐心，这两点非常非常重要。

信息收集的对象：

信息收集该收集什么东西：

根据目标的不同，目标需要什么要素才能运行我们就收集什么要素

一个网站要运行起来，需要什么：

服务器 ip

操作系统

web容器 tomcat

端口

协议 http https

cdn
多地（国外）ping

查历史域名解析记录https://www.ip138.com/

主站 流量大 有cdn　子域名的站 流量小，没有cdn

https 证书

域名

dns　140.100.100.100 baidu.com　域名 ——> ip

用的什么语言

login.php　index.jsp　index.asp

thinkphp

框架 tp cms

数据库

不是绝对：　php——>mysql　开发难度低 中小公司 mysql免费
jsp——>oracle/mysql　oracle 收费而且很贵　流量大的大型公司
asp——>sqlserver　微软自家的

负载均衡

waf

代码泄露

微信小程序

信任域名

界面上的js

接口

信息收集分为2类：

主动信息收集

被动信息收集

4.被动信息收集的基本结构

基本流程：

1.第三方的信息收集机构或平台已经收集到目标的信息

2.第三方的信息收集机构或平台将信息存储在某处

3.攻击者从存储信息的地方查询信息

4.攻击者得到相应信息

5.被动信息收集的特点和应用场景

被动信息收集的优缺点：

优点：

1.隐蔽性高，不容易被发现

2.收集的信息量和覆盖面比较大

缺点：

1.收集到的信息中时效性和准确性不高

2.无法收集到敏感或者未公开的信息

被动信息收集的应用场景：

被动信息收集在实战中非常常用，尤其是在网络安全的攻防对抗中，我们通常见到的各种渗透流程也会经常使用被动信息收集，比如通过被动信息收集获得目标的基本要素，然后根据信息要素判断目标特点并分析弱点，最后根据弱点针对性地做下一步的攻击活动。

6.被动信息收集的常见手段

6.1 通过常规搜索引擎中的信息做信息收集

6.1.1 搜索引擎语法：

仅以google举例：

site：搜索指定站点的内容（通常用来指定目标避免搜索的信息过多）

filetype：搜索指定的文件类型（通常用来搜索dat，log，txt，xls，rar，bak等敏感文件查看敏感内容）

结合使用例子：搜索qq目标下的pdf文件

filetype:pdf site:qq.com

intitle:搜索标题中有指定内容的网页

inurl:搜索url中有指定内容的网页

结合使用例子：wordpress下的alfa插件的敏感信息泄露查询

inurl:ALFA_DATA intitle:"index of"

intext:搜索网页内容中有指定内容的网页

expdb（作业：找一些你感兴趣的东西搜一搜，看看具体的效果）

https://www.exploit-db.com/google-hacking-database

site和inurl的区别：

site：是以域名为基础的 site:jd.com

inurl:是以具体的url路径为基础的 inurl:jd.com

6.1.2 网络空间搜索引擎语法及基本使用：

网络空间搜索引擎基本介绍：

用来网络空间测绘和网络空间安全威胁分析的平台，会定时在整个网络上收集所有对外公开的网络设备相关信息

区别：

搜索引擎：网站

网络空间搜索：只要你开端口

使用方式介绍：

shodan

censys

zoomeye

fofa

quanke

（作业：任意选一个然后搜索某个域名的子域名，不管用什么方式）

基本结构：

官网：

搜索框

账号相关

api

api：

使用方式都差不多：

1.认证

2.查询

语法；

官网说明

以fofa举例：

```
title="abc" 从标题中搜索abc。例：[标题中有北京的网站](https://classic.fofa.so/result?qbase64=dGl0bGU9IuWMl%2BS6rCI%3D)

header="abc" 从http头中搜索abc。例：[jboss服务器](https://classic.fofa.so/result?qbase64=aGVhZGVyPSJqYm9zcyI%3D)

body="abc" 从html正文中搜索abc。例：[正文包含Hacked by](https://classic.fofa.so/result?qbase64=Ym9keT0iSGFja2VkIGJ5Ig%3D%3D)

domain="qq.com" 搜索根域名带有qq.com的网站。例： [根域名是qq.com的网站](https://classic.fofa.so/result?qbase64=ZG9tYWluPSJxcS5jb20i)

host=".gov.cn" 从url中搜索.gov.cn,注意搜索要用host作为名称。例： [政府网站](https://classic.fofa.so/result?qbase64=aG9zdD0iLmdvdi5jbiI%3D), [教育网站](https://classic.fofa.so/result?qbase64=aG9zdD0iLmVkdS5jbiI%3D)
```

port="443" 查找对应443端口的资产。例： [查找对应443端口的资产](https://classic.fofa.so/result?qbase64=cG9ydD0iNDQzIg%3D%3D)

ip="1.1.1.1" 从ip中搜索包含1.1.1.1的网站,注意搜索要用ip作为名称。例： [查询IP为220.181.111.1的网站](https://classic.fofa.so/result?qbase64=aXA9IjIyMC4xODEuMTExLjEi); 如果想要查询网段，可以是：ip="220.181.111.1/24"，例如[查询IP为220.181.111.1的C网段资产](https://classic.fofa.so/result?qbase64=aXA9IjIyMC4xODEuMTExLjEvMjQi)

protocol="https" 搜索指定协议类型(在开启端口扫描的情况下有效)。例： [查询https协议资产](https://classic.fofa.so/result?qbase64=cHJvdG9jb2w9Imh0dHBzIg%3D%3D)

city="Hangzhou" 搜索指定城市的资产。例： [搜索指定城市的资产](https://classic.fofa.so/result?qbase64=Y2l0eT0iSGFuZ3pob3Ui)

region="Zhejiang" 搜索指定行政区的资产。例： [搜索指定行政区的资产](https://classic.fofa.so/result?qbase64=cmVnaW9uPSJaaGVqaWFuZyI%3D)

country="CN" 搜索指定国家(编码)的资产。例： [搜索指定国家(编码)的资产](https://classic.fofa.so/result?qbase64=Y291bnRyeT0iQ04i)

cert="google" 搜索证书(https或者imaps等)中带有google的资产。例： [搜索证书(https或者imaps等)中带有google的资产](https://classic.fofa.so/result?qbase64=Y2VydD0iZ29vZ2xlIg%3D%3D)

banner=users && protocol=ftp 搜索FTP协议中带有users文本的资产。例： [搜索FTP协议中带有users文本的资产](https://classic.fofa.so/result?qbase64=YmFubmVyPXVzZXJzICYmIHByb3RvY29sPWZ0cA%3D%3D)

type=service 搜索所有协议资产，支持subdomain和service两种。例： [搜索所有协议资产](https://classic.fofa.so/result?qbase64=dHlwZT1zZXJ2aWNl)

os=windows 搜索Windows资产。例： [搜索Windows资产](https://classic.fofa.so/result?qbase64=b3M9d2luZG93cw%3D%3D)

server=="Microsoft-IIS/7.5" 搜索IIS 7.5服务器。例： [搜索IIS 7.5服务器](https://classic.fofa.so/result?qbase64=c2VydmVyPT0iTWljcm9zb2Z0LUlJUy83LjUi)

app="海康威视-视频监控" 搜索海康威视设备，[更多app规则](https://classic.fofa.so/rules/library)。例： [搜索海康威视设备](https://classic.fofa.so/result?qbase64=YXBwPSLmtbflurflqIHop4Yt6KeG6aKR55uR5o6nIg%3D%3D)

after="2017" && before="2017-10-01" 时间范围段搜索。例： [时间范围段搜索](https://classic.fofa.so/result?qbase64=YWZ0ZXI9IjIwMTciICYmIGJlZm9yZT0iMjAxNy0xMC0wMSI%3D)，注意： after是大于并且等于，before是小于，这里 after="2017" 就是日期大于并且等于 2017-01-01 的数据，而 before="2017-10-01" 则是小于 2017-10-01 的数据

asn="19551" 搜索指定asn的资产。例： [搜索指定asn的资产](https://classic.fofa.so/result?qbase64=YXNuPSIxOTU1MSI%3D)
as是自治系统　互联里的独立王国 ，大型企业会有自己独立的asn号

org="Amazon.com, Inc." 搜索指定org(组织)的资产。例： [搜索指定org(组织)的资产](https://classic.fofa.so/result?qbase64=b3JnPSJBbWF6b24uY29tLCBJbmMuIg%3D%3D)

base_protocol="udp" 搜索指定udp协议的资产。例： [搜索指定udp协议的资产](https://classic.fofa.so/result?qbase64=YmFzZV9wcm90b2NvbD0idWRwIg%3D%3D)

is_ipv6=true 搜索ipv6的资产,只接受true和false。例： [搜索ipv6的资产](https://classic.fofa.so/result?qbase64=aXNfaXB2Nj10cnVl)

is_domain=true 搜索域名的资产,只接受true和false。例： [搜索域名的资产](https://classic.fofa.so/result?qbase64=aXNfZG9tYWluPXRydWU%3D)

ip_ports="80,443" 或者 ports="80,443" 搜索同时开放80和443端口的ip资产(以ip为单位的资产数据)。例： [搜索同时开放80和443端口的ip](https://classic.fofa.so/result?qbase64=aXBfcG9ydHM9IjgwLDQ0MyI%3D)

ip_ports=="80,443" 或者 ports=="80,443" 搜索同时开放80和443端口的ip资产(以ip为单位的资产数据)。例： [搜索只开放80和443端口的ip](https://classic.fofa.so/result?qbase64=aXBfcG9ydHM9PSI4MCw0NDMi)

ip_country="CN" 搜索中国的ip资产(以ip为单位的资产数据)。例： [搜索中国的ip资产](https://classic.fofa.so/result?qbase64=aXBfY291bnRyeT0iQ04i)

ip_region="Zhejiang" 搜索指定行政区的ip资产(以ip为单位的资产数据)。例： [搜索指定行政区的资产](https://classic.fofa.so/result?qbase64=aXBfcmVnaW9uPSJaaGVqaWFuZyI%3D)

ip_city="Hangzhou" 搜索指定城市的ip资产(以ip为单位的资产数据)。例： [搜索指定城市的资产](https://classic.fofa.so/result?qbase64=aXBfY2l0eT0iSGFuZ3pob3Ui)

ip_after="2019-01-01" 搜索2019-01-01以后的ip资产(以ip为单位的资产数据)。例： [搜索2019-01-01以后的ip资产](https://classic.fofa.so/result?qbase64=aXBfYWZ0ZXI9IjIwMTktMDEtMDEi)

ip_before="2019-01-01" 搜索2019-01-01以前的ip资产(以ip为单位的资产数据)。例： [搜索2019-01-01以前的ip资产](https://classic.fofa.so/result?qbase64=aXBfYmVmb3JlPSIyMDE5LTAxLTAxIg%3D%3D)

实例
"用友U8-OA"　　/yyoa/common/js/menu/test.jsp?doType=101&S1=(SELECT%20MD5(1))

高级搜索：可以使用括号 和 && || !=等符号，如
title="powered by" && title!=discuz
title!="powered by" && body=discuz
(body="content=\"WordPress" || (header="X-Pingback" && header="/xmlrpc.php" && body="/wp-includes/")) && host="gov.cn"
新增==完全匹配的符号，可以加快搜索速度，比如查找qq.com所有host，可以是domain=="qq.com"

6.2 工具

```
衍生工具介绍:
```

坤舆

maltego

7.被动信息收集到的信息的处理

7.1 信息的归类

将收集到的信息以资产的类别分类

7.2 信息的关联

将收集到的信息之间的关系大致标识出来

7.3 信息的筛查

将收集到的信息检查是否存在失效或不准确的进行排除

7.4 信息的重点指出(非常非常重要的内容)

将收集到的信息中的重点内容提出

新开的业务

判断这个资产和最近的公司新闻

边缘业务

非主要盈利来源的业务

外包业务

根据你的经验 看到一个页面或者一个子站点代码逻辑或者说代码风格完全和主站不一样的

主要业务

7.5 信息的拓扑

将重点内容作为信息收集的起点再做一次信息收集

7.6 信息的整合和格式

将所有的信息整合并统一内容保存格式

8.如何编写基本的信息收集工具

8.1 以传统搜索引擎信息收集为例

```
import requests
#任何代码都不是从0开始写
#这个import的意思就是导入别人写好的代码
#requests是什么功能呢？这个相当于模拟我们浏览器的请求

from bs4 import BeautifulSoup
#我们上网看到一个网页其实有很多东西是我们不需要的，上面这个东西就是帮助我们筛选我们想要的内容的
#pip install requests或者bs4 -i https://pypi.tuna.tsinghua.edu.cn/simple

import time
#为了防止请求过快造成一些错误 我们要稍微慢点

domain = input("请输入域名：  ")
#出现一个输入框 输入的值保存到domain里面去

for i in range(48):
    #整个这个缩进 tab={} 都是一个循环 i是一个变量 用来规定我们搜多少信息

    i=i*10
    heads={
      'User-Agent': 'Mozilla/5.0(Windows NT 6.1; Win64; x64; rv:56.0) Gecko/20100101
Firefox/56.0'
  }
    #header是用来规定我们到底模仿哪个浏览器去上网

    url='https://cn.bing.com/search?
q=site%3A'+domain+'&qs=n&form=QBRE&sp=-1&pq=site%3Adgjy.net&sc=2-
11&sk=&cvid=C1A7FC61462345B1A71F431E60467C43&toHttps=1&redig=3FEC4F2BE86247E8AE3BB965A6
2CD454&pn=2&first={}&FROM=PERE'.format(i)
    #具体请求哪个页面

    html=requests.get(url,headers=heads)
    #返回的内容
```

```
    soup=BeautifulSoup(html.content,'html.parser')
    #筛选 初始化一下这个筛选工具

    job_bt=soup.findAll('h2')
    #具体要把哪个地方的东西提出来 如果找到了h2 就把下面整个保存起来

    for i in job_bt:
      time.sleep(3)

      print(i.a.get('href'))
        #获得h2找到的这个东西中间的a标签中的href属性里面的值
      '''
      f = open("result.csv",'a+')
      f.write(i.a.get('href'))
      f.close()
      '''
```

基本思路：

搜索+爬虫

8.2 以网络空间搜索引擎为例

```
# -*- coding: utf-8 -*-
import fofa

if __name__ == "__main__":
    email, key = ('904945036@qq.com','b4b5d6d0c4afae6a9cb82939f03b10b4')
    #输入email和key
    client = fofa.Client(email, key)
    #将email和key传入fofa.Client类进行初始化和验证，并得到一个fofa client对象
    query_str = raw_input('请输入条件')
    print(query_str)
    for page in range(1,51):
        #从第1页查到第50页
        data = client.get_data(query_str,page=page,fields="ip,port")
        #查询第page页数据的ip和端口
        for ip,port in data["results"]:
            print "%s,%s"%(ip,port)
            #打印出每条数据的ip和端口
```

基本思路：

1.api

直接用requests请求对应接口

2.sdk

直接使用sdk中的模块

实战中的被动信息收集都是怎么做的：

多工具，多平台，分布式，结合这三点的大型信息收集综合项目，并且收集到的信息会集中整合和自动化的分析处理

学习Web安全高级攻防、JAVA代码审计、红队攻防，欢迎加入“MS08067安全实验室”（www.ms08067.com）